GOM
GERENCIA DE OBRAS MINA

Preparación para producción y ethical hacking

Brechas, prioridades, alcance de pruebas y evidencia de aprobación

ESTADO	RESULTADO CLAVE
PREPARACIÓN PARCIAL	**P0 + P1** **bloqueadores de producción y requisitos previos al pentest formal**

Fecha de evaluación

16 de octubre de 2026

Alcance

Backend Node.js, frontend React, dependencias, configuración HTTP y preparación operativa.

Documento preparado para revisión ejecutiva y técnica. No sustituye un pentest externo autorizado.

1. Objetivo

Definir qué falta desde el estado actual de ADP Casino hasta una condición razonable de entrada a producción y a una evaluación formal de ethical hacking.

La referencia recomendada es OWASP ASVS 5.0 nivel 2, complementada con OWASP API Security Top 10. La aceptación final depende además de las políticas internas de Agrosuper, clasificación de datos, infraestructura y tolerancia de riesgo.

2. Evaluación general

Dimensión	Estado actual	Objetivo previo a producción	Evaluación
Funcionalidad	Flujos principales implementados; aprobación/rechazo pendiente de validación funcional con usuarios	UAT firmada para cada rol y Casino	Parcial
Autenticación	`scrypt` moderno con fallback legado	Sin claves recuperables, hash versionado y MFA administrativo	Brecha alta
Sesiones	Token opaco, hash en SQL, cookie protegida y expiración absoluta	Revocación por eventos, expiración inactiva, monitoreo y pruebas CSRF	Parcial
Autorización	Permisos backend y contexto multiempresa	Matriz negativa completa y eliminación de bypasses de compatibilidad no aprobados	Parcial avanzado
Protección API	CORS, límites, headers, errores y rate limit inicial	Rate limit distribuido, protección CSRF formal y límites por flujo de negocio	Parcial
Dependencias	Frontend 0; backend sin críticas y con 10 observaciones	Sin críticas; altas con remediación o aceptación formal de riesgo y alcance	Parcial
Secretos	Retirados del código actual	Secretos rotados, mínimo privilegio, gestor seguro y evidencia de revocación	No cumplido
SQL/TLS	Configuración existente pendiente de corrección validada	TLS con certificado confiable y cuenta de mínimo privilegio	No cumplido
Logging y monitoreo	Logs técnicos parciales	Auditoría de autenticación, permisos, datos sensibles y alertas centralizadas	No cumplido
Privacidad	Aislamiento por empresa; acceso amplio a Personas para sistemas 10/55	Justificación de acceso, minimización, retención y trazabilidad	Parcial
Contenedor	Dockerfile endurecido en código	Imagen construida, escaneada, firmada y ejecutada en homologación	Parcial
Recuperación	No validada en esta revisión	Backup, restauración y continuidad probados	No evaluado
Pentest	Smoke test local 5/5	Pentest externo autorizado, remediación y revalidación	Pendiente

3. Bloqueadores de producción

Los siguientes puntos deben cerrarse antes de una aprobación productiva:

P0 - obligatorios

1. Rotar la API key y la credencial SQL anteriormente publicadas.
2. Confirmar revocación de los valores anteriores y revisar registros de uso.
3. Crear una identidad SQL exclusiva, sin `sa`, con permisos mínimos sobre

`BDADP_CASINO`.

4. Configurar TLS hacia SQL Server con validación de certificado.

5. Definir y ejecutar el corte de claves legadas o un plan fechado de migración forzada.
6. Construir y escanear la imagen Docker final; comprobar que no contiene `.env`, Git, documentos, PDFs, backups o secretos.
7. Ejecutar UAT controlada de creación, envío, historial, aprobación y rechazo usando usuarios de negocio de cada Casino.
8. Corregir la fotografía de `verify:casino` y obtener una ejecución satisfactoria.

P1 - necesarios para ethical hacking

1. Implementar auditoría persistente de:
   - login exitoso y fallido;
   - rate limit y bloqueos;
   - acceso denegado;
   - altas, bajas y cambios de usuarios, roles y permisos;
   - cambio de contraseña y revocación de sesiones;
   - aprobaciones, rechazos y transiciones inválidas.
2. Revocar las demás sesiones al cambiar o restablecer una clave.
3. Validar `UsuExpira` o documentar formalmente por qué no gobierna el acceso.
4. Definir MFA para `ADMINFULL` y cuentas de emergencia.
5. Revisar el acceso amplio a Personas y fotos para sistemas 10/55.
6. Sustituir el rate limit en memoria por uno compartido si habrá más de una instancia.
7. Agregar protección CSRF mediante token o validación estricta de origen para todas las mutaciones, comprobando el dominio real de frontend y backend.
8. Definir si el nivel histórico 900 y `SECURITY_ADMIN_LOGINS` seguirán concediendo administración de Seguridad.
9. Resolver las dependencias residuales: retirar módulos heredados no usados o aislar y probar una actualización segura de Puppeteer.

P2 - madurez operativa

1. Centralizar logs y alertas en SIEM o plataforma equivalente.
2. Documentar retención, enmascaramiento y acceso a información personal.
3. Configurar escaneo de secretos, SCA, SAST e imagen en CI/CD.
4. Generar SBOM por versión desplegada.
5. Firmar y conservar trazabilidad de imágenes y artefactos.
6. Probar backup, restauración y recuperación ante desastre.
7. Establecer proceso de parches con SLA por severidad.
8. Mantener inventario de endpoints activos y retirar código heredado no publicado.

4. Alcance propuesto para ethical hacking

Autenticación

- enumeración de usuarios por RUT, empresa, tiempos y mensajes;
- fuerza bruta, password spraying y credential stuffing controlados;
- claves comunes, largas, Unicode y legadas;
- expiración, cambio, recuperación y sesiones concurrentes;
- bypass de estado de usuario y fecha de expiración.

Sesión y navegador

- fijación, robo, repetición y revocación de cookies;
- atributos `Secure`, `HttpOnly`, `SameSite` y prefijo de cookie;
- CSRF en `POST`, `PUT`, `PATCH` y `DELETE`;
- CORS con orígenes, subdominios, `null`, puertos y esquemas distintos;
- caché, historial, referrer y exposición en source maps.

Autorización e IDOR

- sustituir `EmpCod` y `GECODEMP` en query, body, headers y cookies;
- consultar RUT, foto o pedido de otra empresa;
- consultar o decidir pedidos de otro Casino;
- cambiar `requesterRut`, `casinoId`, número de pedido y códigos de producto;
- acceder a Seguridad sin `ADMINFULL`;
- probar roles directos, heredados, nivel 900 y acciones `ASIGPROG1`;
- llamar directamente a endpoints ocultos en React.

Reglas Casino

- manipulación de precios y productos de otro Casino;
- transición de estados fuera de secuencia;
- aprobación/rechazo repetidos y solicitudes concurrentes;
- duplicación, replay y carreras sobre correlativos;
- cantidades, fechas, horas y textos en límites y fuera de rango;
- fallo parcial para confirmar rollback de cabecera y detalle.

Ataques técnicos

- SQL injection, XSS almacenado/reflejado y CSV injection;
- prototype pollution, mass assignment y HTTP parameter pollution;
- verb tampering y content types alternativos;
- payloads grandes, lentos o profundamente anidados;
- path traversal, archivos y XML si se habilitan rutas heredadas;
- SSRF y ejecución de navegador si se publica Puppeteer;

- exposición de errores, versiones, documentos o secretos.

Infraestructura

- TLS externo e interno, certificados y protocolos habilitados;
- puertos, reverse proxy, headers y límites de tiempo;
- privilegios de la cuenta SQL y segmentación de red;
- contenido y usuario efectivo de la imagen;
- vulnerabilidades de sistema operativo y paquetes de la imagen.

5. Evidencia requerida para aprobar

Evidencia	Criterio mínimo
Rotación de secretos	Identificadores nuevos activos y anteriores revocados, sin publicar valores
Auditoría de dependencias	Sin críticas; altas resueltas o aceptadas formalmente con justificación de alcance
Pruebas backend	Suite completa correcta
Verificación de base	`npm run verify:casino` correcta contra el ambiente candidato
Frontend	ESLint y build correctos, sin source maps de producción
UAT	Firma o registro de aceptación por roles y Casinos representativos
Imagen	Escaneo sin críticas, sin secretos y ejecución no privilegiada
Autorización	Casos positivos y negativos por empresa, Casino, programa y rol
Backup	Restauración comprobada con tiempo y punto de recuperación documentados
Pentest	Informe, plan de remediación y re-test de hallazgos altos/críticos

6. Criterio de salida sugerido

La aplicación puede considerarse candidata a producción cuando:

- no existan hallazgos críticos abiertos;
- todo hallazgo alto esté corregido o tenga aceptación formal, responsable y fecha;
- los secretos expuestos estén rotados;
- UAT, verificación de base, build, pruebas y escaneo de imagen sean satisfactorios;
- la matriz multiempresa y multi-Casino tenga pruebas negativas;
- exista monitoreo, auditoría y capacidad comprobada de recuperación;
- el ethical hacking haya completado su re-test.

7. Referencias

- OWASP ASVS, versión estable 5.0.
- OWASP API Security Top 10.
- OWASP Password Storage Cheat Sheet.
- OWASP Session Management Cheat Sheet.
- OWASP Secrets Management Cheat Sheet.